Secure By Design

EDUCATE. EMPOWER. SECURE THE FUTURE.

COURSE 1.8 / COMPANION WORKBOOK

Patch, protect, and watch for weakness

WSUS rings, approved sources, ePO & credentialed scanning

Keep the proven state from drifting: Windows updates through WSUS rings fed across the air gap, one approved source per software type with SBD-REPO01 for packages, a living inventory on SBD-MGMT01, managed endpoint protection through SBD-EPO01, and SBD-NESSUS01 turning the scan cadence into routine.

MATERIALS EDITION 1.4 / COURSE 1.8

Updated 9 October 2026 · sbd-patch-protect

NAME _____ / DATE _____

Table of contents

Read each lesson alongside the interactive guide and the video. Use the record tables to write down what you actually observe — the workbook is your evidence, not the guide.

Before you start

01 Design the rings and the software rules

02 Build SBD-WSUS01 and the ring policies

03 Build SBD-REPO01 for approved packages

04 SBD-MGMT01 and the living inventory

05 Endpoint protection through SBD-EPO01

06 SBD-NESSUS01 and the standing cadence

Course review and sign-off

> **HOW TO USE IT** Each lesson page has the same shape: what you will learn, the build steps, the commands that verify them, and a record table. Fill the table from your own environment — never from the sample values.

Before you start

This course keeps the proven state from drifting: updates and software arrive only through controlled channels, every endpoint runs managed protection, and a credentialed scanner turns the course 1.3 cadence into routine. In an air-gapped lab, every one of these systems feeds on content carried across the boundary — which is the recurring lesson.

Prerequisites

- ☐ Complete course 1.7: the fleet exists, inventoried and reporting into the logging pipeline.
- ☐ Provision SBD-WSUS01 (10.0.20.30), SBD-REPO01 (10.0.70.20, Linux), SBD-MGMT01 (10.0.70.10), SBD-EPO01 (10.0.50.30), and SBD-NESSUS01 (10.0.50.20) per the model's placements.
- ☐ Keep the approved-media process ready: update content, package mirrors, protection definitions, and scanner plugins all cross the air gap the same reviewed, hashed way.

What this course builds

- Deliver updates and software through ring-gated, single-source, air-gap-fed channels.
- Prove protection coverage against a living component inventory.
- Run credentialed vulnerability scanning on the standing cadence with classified findings.

Systems in scope

RECORD	YOUR OBSERVATION
SBD-WSUS01 — name, address, OS build	
SBD-REPO01 — name, address, OS build	
SBD-MGMT01 — name, address, OS build	
SBD-EPO01 — name, address, OS build	
SBD-NESSUS01 — name, address, OS build	

© 2026 Secure By Design Team LLC.

LESSON 01 / ABOUT 20 MIN

Design the rings and the software rules

> **WHY THIS MATTERS** Decide how change reaches the network before any of it does: update rings that try things on the expendable before the essential, one approved source per software type, and register rows for every new path.

In this lesson you will

- Define the update rings and their order.
- Set the one-approved-source rule per software type.
- Register the course's service paths.

Follow the build

1. Define three rings and their order: a pilot ring (the course 1.7 sample machines plus one member server), the broad ring (fleet and member servers), and the critical ring last (domain controllers and both VLAN 30 hosts) — updates earn their way up, never down.
2. Write the software rule: Windows updates come only from SBD-WSUS01, Linux packages only from SBD-REPO01, protection definitions only through SBD-EPO01, and anything else arrives as a documented exception — one source per type is what makes 'unauthorized software' a checkable claim.
3. Decide the air-gap feeding cadence: what content crosses on media, how often, hashed by whom — the course 1.3 transfer procedure, now on a schedule.
4. Add the register rows: every Windows system to WSUS (8530/8531), domain controllers included; the domain-joined Linux servers (SBD-SPLUNK01 and SBD-NESSUS01) to REPO01 (HTTP, GPG-signed packages); every Windows system's agent to Trellix ePolicy Orchestrator (ePO) on SBD-EPO01 on its agent-server secure port, TCP 443, with the agent starting each connection; and the scanner's credentialed reach into each VLAN (SMB 445 and WMI to Windows, SSH 22 to Linux) — the one deliberate wide permit, owned and logged.

Check your result

```
# Capture the before state: where machines currently look for updates (nowhere internal
yet).
Get-ItemProperty 'HKLM:\SOFTWARE\Policies\Microsoft\Windows\WindowsUpdate' -ErrorAction
SilentlyContinue
Get-ADComputer -Filter * -SearchBase 'OU=SBD,DC=sbd,DC=test' | Measure-Object
```

> **WHAT SUCCESS LOOKS LIKE** The ring table names every system's ring, the one-source rule and feeding cadence are written, and the register carries the course's rows with owners.

Your record

Evidence to keep: Keep the ring assignments, the software source rules, the feeding cadence, and the new register rows.

RECORD	YOUR OBSERVATION
Host(s) and time collected	

RECORD	YOUR OBSERVATION
Observed result	
Differences from the plan	
Evidence file names	
Open items or findings	

Think it through

Why do domain controllers sit in the last ring?

> **REMEMBER** Pilot → broad → critical: updates earn their way up. One named source per software type, exceptions documented. Every path — including the scanner's wide one — is a register row.

Microsoft · Windows Server Update Services (WSUS)

NIST · SP 800-53 Rev. 5 security controls

LESSON 02 / ABOUT 30 MIN

Build SBD-WSUS01 and the ring policies

> **WHY THIS MATTERS** WSUS becomes the only road Windows updates travel: content imported across the air gap, approvals per ring, and Group Policy objects (GPOs) that point every OU at the server — with a pilot ring that proves each approval first.

In this lesson you will

- Install WSUS and import content through the offline process.
- Map rings to WSUS groups and OU-linked policies.
- Approve and verify a first update cycle through the pilot ring.

Follow the build

1. Install the WSUS role on SBD-WSUS01, scope its products and classifications to what the network actually runs — the Windows Server and Windows client releases in use, and Defender definitions — and nothing speculative. Microsoft announced in September 2024 that WSUS is deprecated and no longer actively developed, but it is still included in Windows Server and supported for production deployments, with security and quality updates under the product lifecycle.
2. Feed it offline: export the needed content on the connected side, hash it, carry it across, and import — the WSUS offline servicing path is the course 1.3 media procedure wearing an update hat.
3. Create WSUS computer groups matching the rings, and link ring GPOs at the OUs: update source SBD-WSUS01, the ring's group assignment, and install/restart windows that respect what each ring does for a living. The critical ring's GPO links to the Domain Controllers and Tier 0 Servers OUs.
4. Approve one update cycle for the pilot ring only, watch it install and report, then promote the approval ring by ring — the critical ring installs only what two rings already survived. Pilot and broad-ring approvals are Tier 1 work from SBD-ADMIN-SRV01; critical-ring approvals for the domain controllers and the two Tier 0 servers are Tier 0 work from AdminJumpBox01. Add SBD-WSUS01 to the SBD Tier 0 Console Hosts group and restart it so the new membership applies: the console reaches the server as a Kerberos network logon, the one Tier 0 logon type course 1.5's deny policy leaves open there, as its exception record states.

Check your result

```
Get-WsusServer | Get-WsusComputer -ComputerTargetGroups 'Ring 1 - Pilot' | Select-Object
FullDomainName, LastReportedStatusTime
gpresult /r /scope:computer
Get-WindowsUpdateLog -ErrorAction SilentlyContinue
```

> **WHAT SUCCESS LOOKS LIKE** Every system reports to its ring's group, the pilot ring installed and reported the first approved cycle, and the promotion to later rings followed the written order.

Your record

Evidence to keep: Record the product scope, the offline import with hashes, the ring GPO reports, and the first cycle's per-ring approval and install timeline.

RECORD	YOUR OBSERVATION
Host(s) and time collected	
Observed result	
Differences from the plan	
Evidence file names	
Open items or findings	

Think it through

How does update content reach this WSUS server?

REMEMBER Updates travel one road: offline import, ring approvals, OU policies. The pilot ring absorbs the risk; the critical ring inherits the proof. The first full cycle is on record, ring by ring.

Microsoft · Windows Server Update Services (WSUS)

Microsoft · Features removed or no longer developed in Windows Server

DISA · SRG/STIG tools (SCC and STIG Viewer)

LESSON 03 / ABOUT 20 MIN

Build SBD-REPO01 for approved packages

WHY THIS MATTERS The lab's Linux hosts and tooling need packages, and the rule from lesson 1 applies to them too: one internal repository, fed across the boundary, serving only what was reviewed in.

In this lesson you will

- Stand up the internal package repository on SBD-REPO01.
- Mirror the approved package set through the offline process.
- Point the Linux consumers at the repository and nothing else.

Follow the build

1. Build SBD-REPO01 per your Linux platform plan and serve a repository directory over HTTP at 10.0.70.20 — the register row from lesson 1 already permits the path from its consumers.
2. Mirror the approved package set on the connected side, hash the set, carry it across, and verify before publishing — same ceremony, different payload; record the repository's snapshot date as its version.
3. Configure each Linux consumer (the analysis platform's host if Linux, the scanner appliance's feeds where applicable) to use only the internal repository — remove or disable every external source definition so the one-source rule is configuration, not convention.
4. Document the repository's own administration under the tier model — managed from VLAN 60, changes recorded — and its assessable record: the hashed snapshot catalog, like the router's config export.

Check your result

```
Test-NetConnection 10.0.70.20 -Port 80
# On a Linux consumer: confirm the only configured source is the internal repository
# dnf repolist  (or the platform equivalent) — capture the output into the evidence set
Get-FileHash -Algorithm SHA256 C:\Evidence\patch-protect\repo-snapshot-catalog.txt
```

WHAT SUCCESS LOOKS LIKE The repository answers on its registered path, consumers list the internal source and only the internal source, and the snapshot catalog with hashes is filed.

Your record

Evidence to keep: Keep the snapshot date and hash catalog, the consumer source listings, and the repository's administration record.

RECORD	YOUR OBSERVATION
Host(s) and time collected	
Observed result	
Differences from the plan	

RECORD	YOUR OBSERVATION
Evidence file names	
Open items or findings	

Think it through

What is the repository's version, for evidence purposes?

REMEMBER One internal repository, fed by the same boundary ceremony. Consumers can only see the approved source — by configuration. The dated, hashed snapshot is the version of record.

Red Hat · product documentation

NIST · SP 800-53 Rev. 5 security controls

LESSON 04 / ABOUT 25 MIN

SBD-MGMT01 and the living inventory

> **WHY THIS MATTERS** The course 1.7 fleet inventory was a snapshot; SBD-MGMT01 makes it a living record — every system, its ring, its sources, its last-seen state — maintained from the management seat the model placed in VLAN 70.

In this lesson you will

- Stand up the management tooling host under the tier model.
- Build the component inventory covering all modeled systems.
- Define how the inventory stays current and who owns it.

Follow the build

1. Build SBD-MGMT01 in the Servers OU, administered from VLAN 60 per the tier rules, with your chosen configuration and inventory tooling — the record matters more than the brand.
2. Load the inventory with every system the network now has — the 1.7 fleet list, the servers, the admin plane, the router — each with its OU, VLAN, address, ring, software sources, and scan status: the CM-8 component inventory, in one place.
3. Define currency: joins and retirements update the inventory as part of their process, and a monthly reconciliation compares the inventory against the directory and the DHCP leases — drift between them is a finding.
4. Name the owner and file the inventory's first reconciliation as evidence; course 2.2 shows how a record like this one joins the Body of Evidence for the configuration-management controls.

Check your result

```
Get-ADComputer -Filter * -SearchBase 'OU=SBD,DC=sbd,DC=test' | Measure-Object
Get-DhcpServerv4Lease -ScopeId 10.0.80.0 | Measure-Object
# Compare both counts against the inventory's totals and record the reconciliation
```

> **WHAT SUCCESS LOOKS LIKE** The inventory lists every modeled system with its attributes, the first directory-and-DHCP reconciliation matches (or its mismatches are findings), and ownership and cadence are written.

Your record

Evidence to keep: Keep the populated inventory export, the reconciliation record, and the ownership and cadence note.

RECORD	YOUR OBSERVATION
Host(s) and time collected	
Observed result	
Differences from the plan	

© 2026 Secure By Design Team LLC.

RECORD	YOUR OBSERVATION
Evidence file names	
Open items or findings	

Think it through

What makes an inventory 'living' rather than a stale spreadsheet?

> **REMEMBER** One record of everything, with ring, sources, and scan status. Reconciliation against directory and leases keeps it honest. Owned, scheduled, and ready to join the Body of Evidence.

NIST · SP 800-53 Rev. 5 security controls

LESSON 05 / ABOUT 30 MIN

Endpoint protection through SBD-EPO01

WHY THIS MATTERS Protection becomes a managed fact, not fifty local settings: the ePO server deploys agents ring by ring, policy comes from one console, and the fleet's protection state is something the dashboard can simply show.

In this lesson you will

- Stand up the ePO server and its agent deployment.
- Apply the protection and DLP policy baseline by ring.
- Verify coverage and wire detections into the pipeline.

Follow the build

1. Build SBD-EPO01 in VLAN 50, fed its definitions through the offline process on the lesson-1 cadence, with its console reachable only from the admin plane — the register row from lesson 1 carries the agents' check-ins, and with the agent's peer-to-peer and RelayServer features turned off, endpoints open no listener for the server (TCP 8081, UDP 8082).
2. Deploy agents to the pilot ring first, confirm check-ins, then follow the ring order through the fleet, the member servers, and the critical ring — the same earn-your-way-up discipline as updates. Agent policy for the domain controllers is a Tier 0 scope in ePO, changed only from AdminJumpBox01 with a Tier 0 account. Add SBD-EPO01 to the SBD Tier 0 Console Hosts group and restart it, so course 1.5's recorded network-logon exception covers that console.
3. Apply the policy baseline: on-access protection, the scan schedule, and the data-loss-prevention policy scoped to what the model's DLP role calls for — each setting a decision in the record, not a default accepted silently.
4. Verify coverage against the living inventory — every endpoint present and checking in — and forward the server's threat events into the course 1.6 pipeline so detections land beside everything else; a standard test file makes the whole path fire once, on record.

Check your result

```
Test-NetConnection SBD-EPO01.sbd.test -Port 443
Get-Service -ComputerName SBD-PC01 -Name 'masvc' -ErrorAction SilentlyContinue | Select-Object Status
Get-WinEvent -LogName ForwardedEvents -MaxEvents 5 | Select-Object TimeCreated, MachineName
```

WHAT SUCCESS LOOKS LIKE Every inventoried endpoint shows a checking-in agent, the policy baseline is applied and recorded, and a test detection traveled from endpoint to console to the analyst's search.

Your record

Evidence to keep: Keep the coverage-vs-inventory comparison, the policy baseline record, and the traced test detection.

RECORD	YOUR OBSERVATION
Host(s) and time collected	

Think it through

What answers 'is every endpoint protected'?

REMEMBER Agents by ring, policy from one console, console from the admin plane. Coverage is proven against the inventory, not assumed. Detections join the pipeline — one screen tells the whole story.

Trellix · product documentation

NIST · SP 800-53 Rev. 5 security controls

LESSON 06 / ABOUT 25 MIN

SBD-NESSUS01 and the standing cadence

> **WHY THIS MATTERS** The course 1.3 cadence grows its instrument: credentialed scans per VLAN on schedule, findings flowing into the pipeline and the Plan of Action and Milestones (POA&M) habit, and this course's five new systems getting their own baselines on the way out.

In this lesson you will

- Stand up the scanner with least-privilege credentialed access.
- Run the first full-network credentialed scan and triage it.
- Fold scanning into the standing cadence and close the course's scans.

Follow the build

1. Build SBD-NESSUS01 on Linux in VLAN 50, joined to the sbd.test domain with its time taken from both domain controllers, plugins fed on the offline cadence, with dedicated scan accounts — least privilege for credentialed checks, its use logged, its register row the deliberate wide permit from lesson 1. The account that scans the domain controllers is a Tier 0 credential, kept apart from the member-server scan account and used only for DC scan jobs. Allow the scanner through the host firewalls it must reach — on the fleet, add SBD-NESSUS01 to the course 1.7 workstation firewall policy for SMB 445 and WMI.
2. Run the first credentialed scan VLAN by VLAN against the inventory, and triage like the course 1.3 rescan taught: every finding becomes fix-now, documented deviation, or POA&M candidate — never unexplained.
3. Wire results outward: findings into the analysis pipeline for trending, the triage into the living exception record, and the scan schedule into the cadence — quarterly with the Defense Information Systems Agency (DISA) release cycle, plus change-triggered, now automated enough to keep.
4. Close this course's own books: baselines for WSUS01, REPO01 (config-export pattern), MGMT01, EPO01, and NESSUS01, rescans where agents and policies changed existing systems, and the handoff — the network now sustains itself; course 1.9 finally gives it something to serve.

Check your result

```
Test-NetConnection SBD-NESSUS01.sbd.test -Port 8834
Get-ChildItem C:\Evidence\patch-protect -Recurse | Select-Object Name, LastWriteTime
Get-FileHash -Algorithm SHA256 C:\Evidence\patch-protect\*
```

> **WHAT SUCCESS LOOKS LIKE** The credentialed scan covered the inventory with the scan account's use logged, every finding is classified, results and schedule are wired into pipeline and cadence, and the course's baselines and rescans are filed.

Your record

Evidence to keep: Keep the scan summary with its triage, the scan-account and register records, the cadence entry, and the course's scan set.

RECORD	YOUR OBSERVATION
Host(s) and time collected	

RECORD	YOUR OBSERVATION
Observed result	
Differences from the plan	
Evidence file names	
Open items or findings	

Think it through

Why credentialed scans rather than unauthenticated ones?

> **REMEMBER** Credentialed, least-privilege, logged — the scanner earns its wide row. Findings end classified and flow into pipeline and records. This course's systems are baselined; the network now maintains itself.

Tenable · Nessus documentation

DISA · SRG/STIG tools (SCC and STIG Viewer)

NIST · SP 800-53 Rev. 5 security controls

Course review and sign-off

Before moving on, confirm each lesson left evidence behind — and that what remains open is written down, not remembered.

Lesson completion

LESSON	EVIDENCE FILED	DATE
01 Design the rings and the software rules	☐ yes	
02 Build SBD-WSUS01 and the ring policies	☐ yes	
03 Build SBD-REPO01 for approved packages	☐ yes	
04 SBD-MGMT01 and the living inventory	☐ yes	
05 Endpoint protection through SBD-EPO01	☐ yes	
06 SBD-NESSUS01 and the standing cadence	☐ yes	

Open items carried forward

Next in the learning path

That completes course 1.8. Course 1.9 stands up the business services the users actually came for — file, database, licensing, and web.

> **KEEP IT HONEST** Lesson completion records learning activity; it is not a system authorization decision. Your observations, not the sample values, establish what happened in your environment.

© 2026 Secure By Design Team LLC.